

MULTI-FACTOR AUTHENTICATION DEMO

Report Project: Implement Password + OTP/TOTP Authentication with Recovery Controls

Environment: Kali Linux

Introduction

Multi-Factor Authentication (MFA) is a security method that requires two or more different proof factors to verify your identity before granting access to an account or system.

Project Objectives

User registration and password authentication.

TOTP-based second-factor authentication.

Create a QR code for enrolling in an authenticator app.

Generate recovery codes for account restoration.

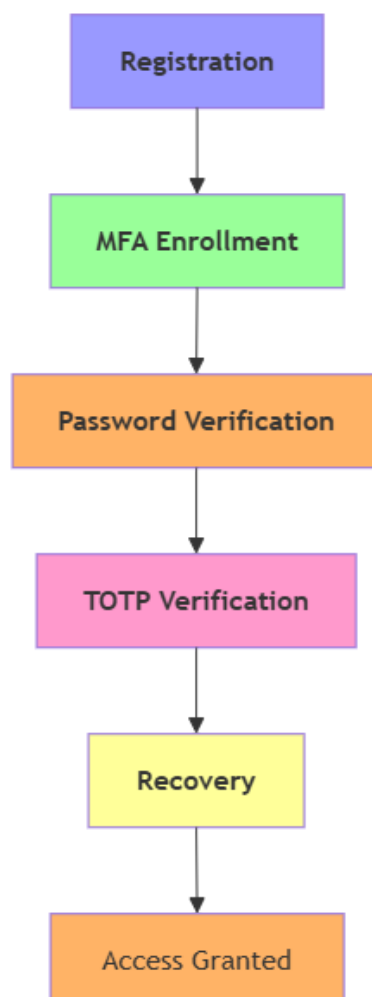
Securely store recovery codes.

Ensure recovery codes cannot be reused after a successful recovery.

Scope

No real user credentials are used in this Project.

Authentication Workflow



Registration: A synthetic user creates an account. The password is converted into a password hash before storage.

MFA Enrollment: The application creates a TOTP secret and provisioning URI, then generates a QR code. The user scans the QR code with an authenticator application.

Password Verification: During login, the submitted password is checked against the stored password hash.

TOTP Verification: After the password succeeds, the user enters the current six-digit TOTP. The application verifies it using the stored TOTP secret.

Recovery: If TOTP cannot be used, an unused recovery code can be entered. After successful use, that code is marked as used.

Reuse Prevention: A previously used recovery code is rejected, preventing the same recovery credential from being used repeatedly.

Source Code

app.py: Contains the Flask routes and controls the registration, login, MFA verification, recovery, dashboard, and logout flow.

mfa.py: Contains the core MFA functions including TOTP secret generation, TOTP validation, QR creation, recovery-code generation, and recovery-code hashing.

database.py: Provides SQLite operations for user records and recovery-code records.

test_mfa.py: Contains automated tests for valid/invalid TOTP behavior, recovery-code uniqueness, and hashing.

Security Features

TOTP provides a time-based second authentication factor.

QR enrollment simplifies TOTP setup for the demonstration.

Recovery codes are marked as used after successful recovery.

Used recovery codes cannot be reused.

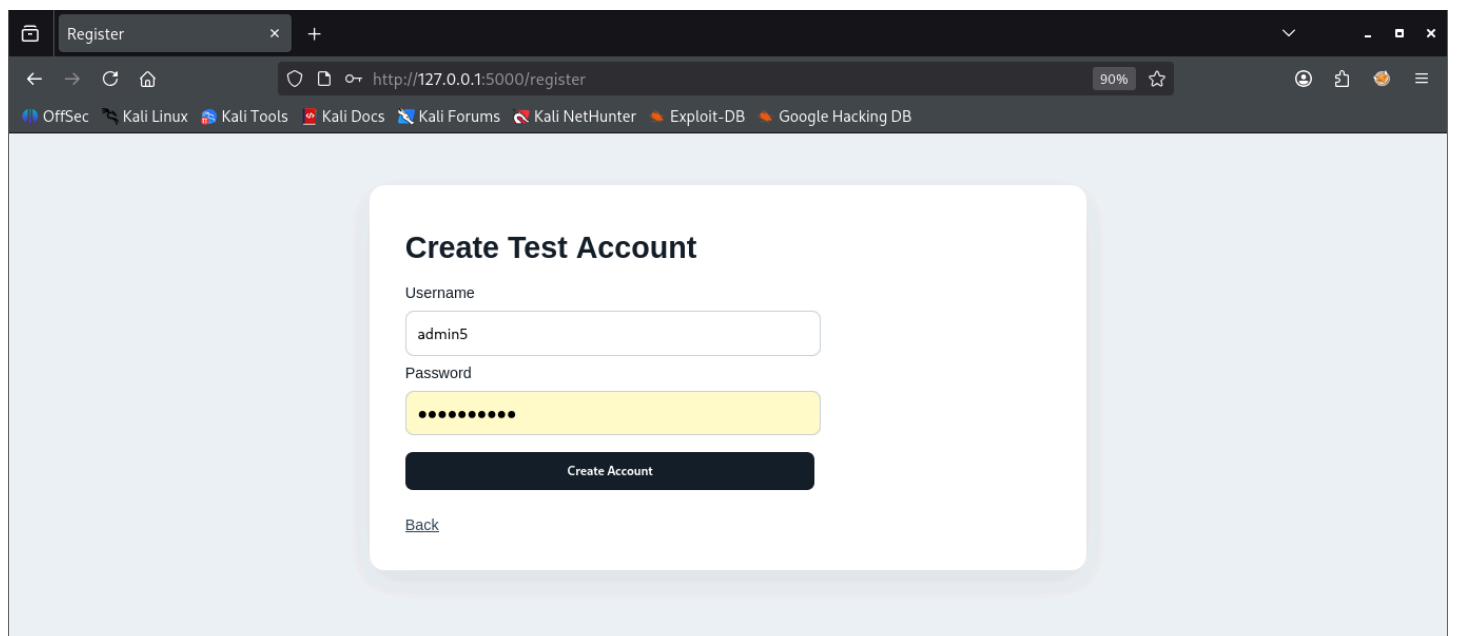
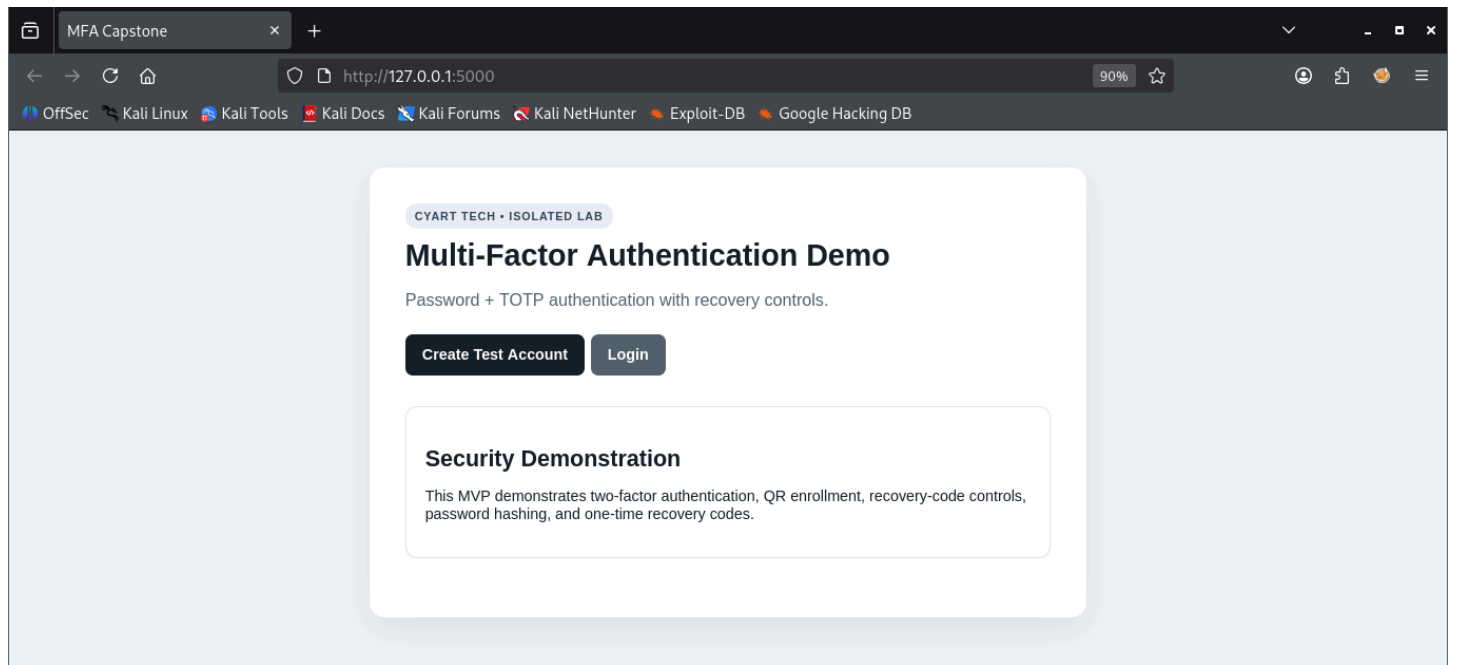
Username, Password and TOTP input validation.

Proof

User Registration

Expected Result: Account created

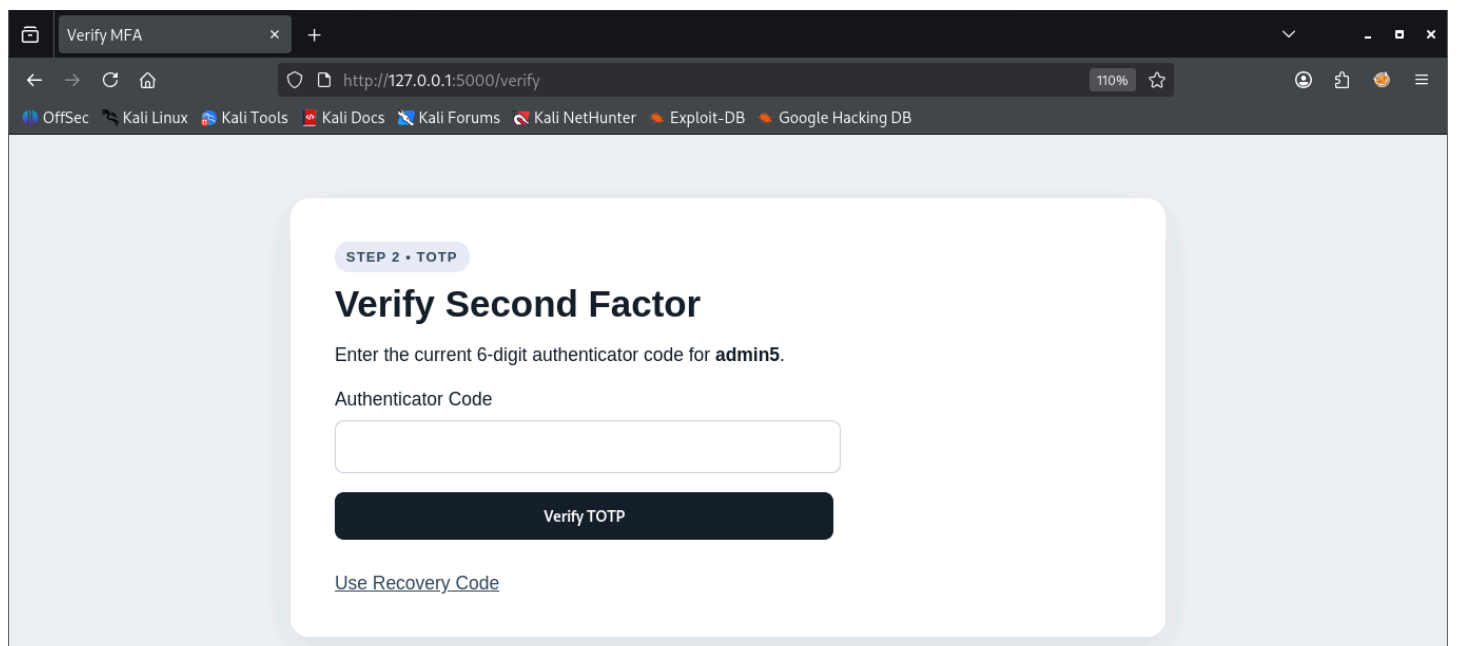
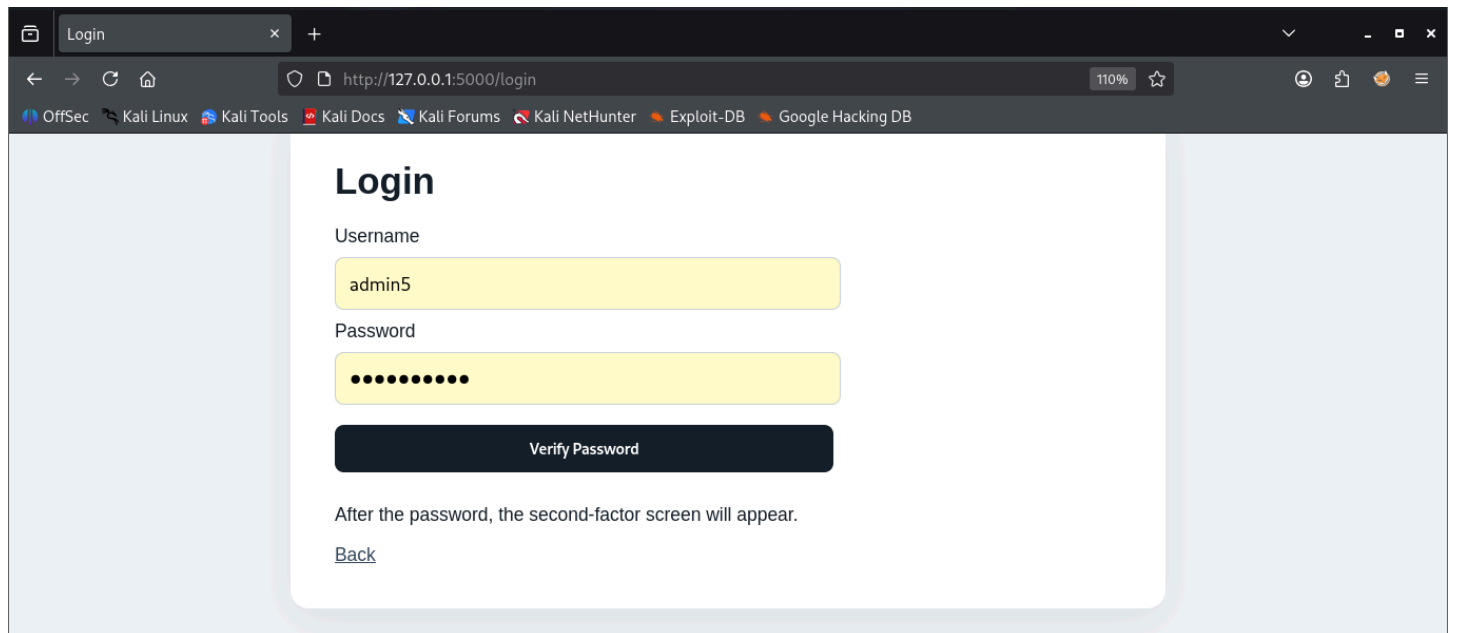
Status: PASS



Correct Password

Expected Result: Password accepted

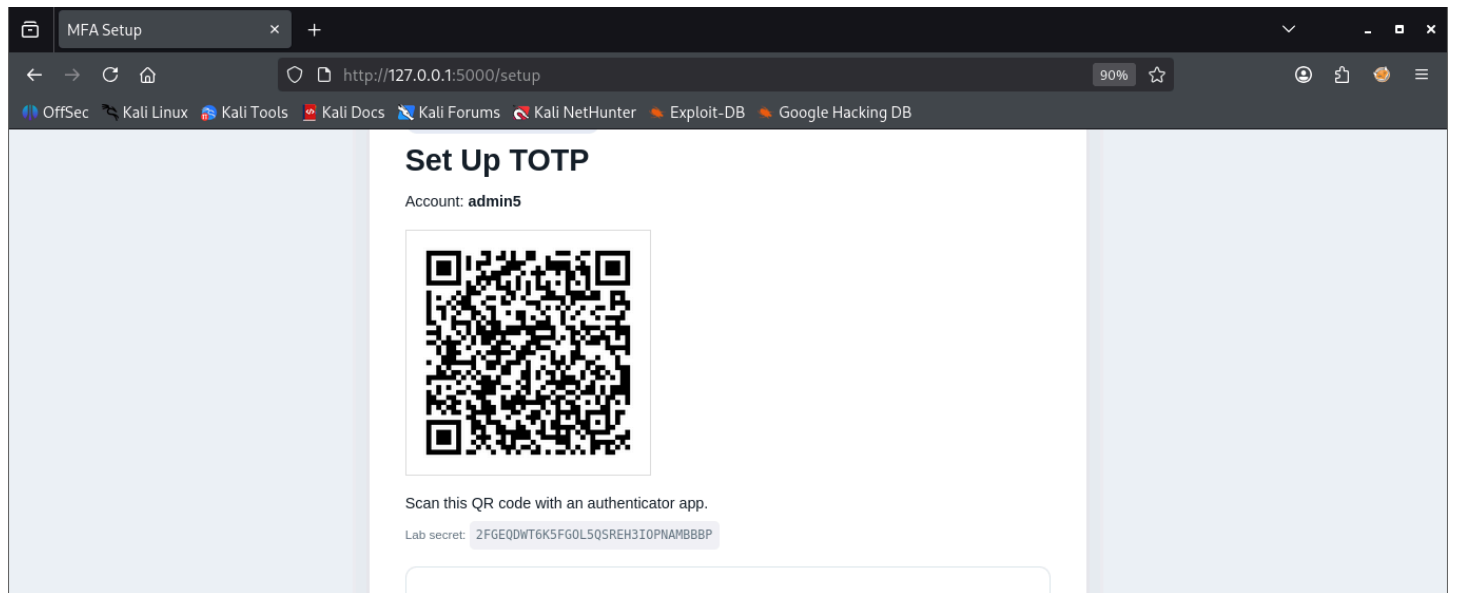
Status: PASS



TOTP Setup

Expected Result: QR generated

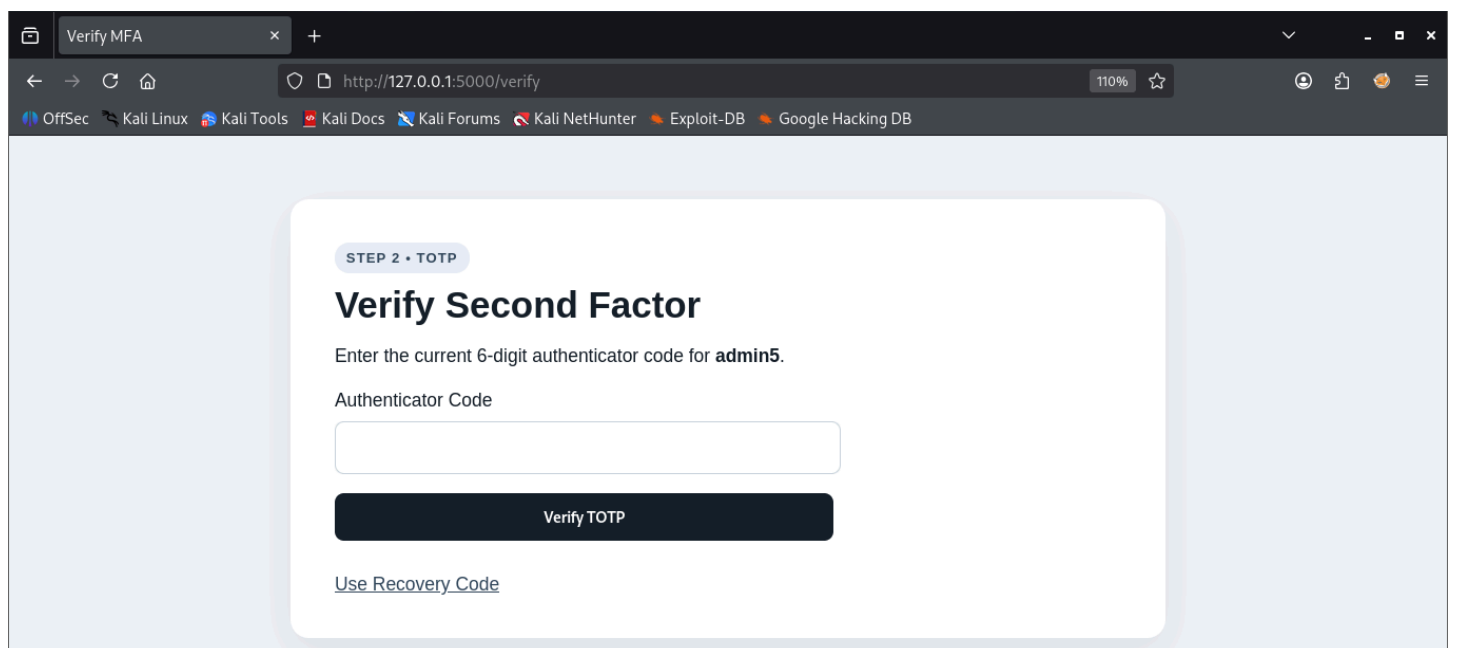
Status: PASS

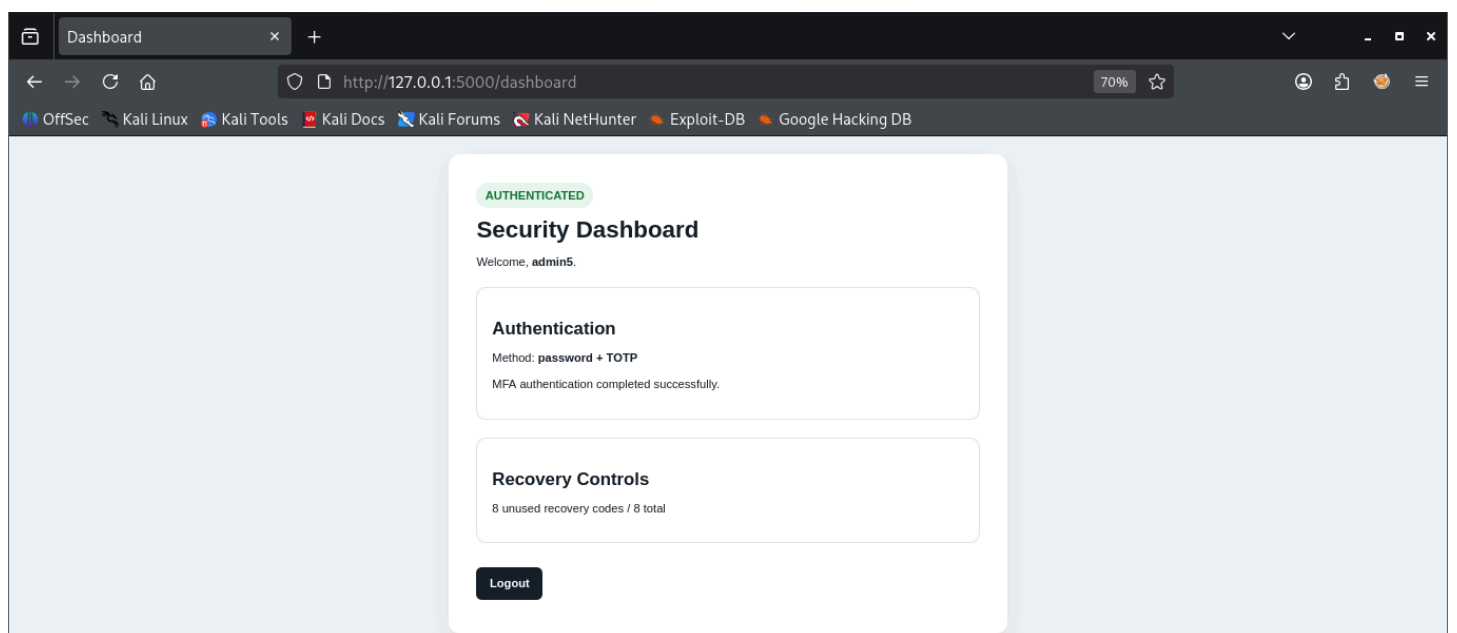
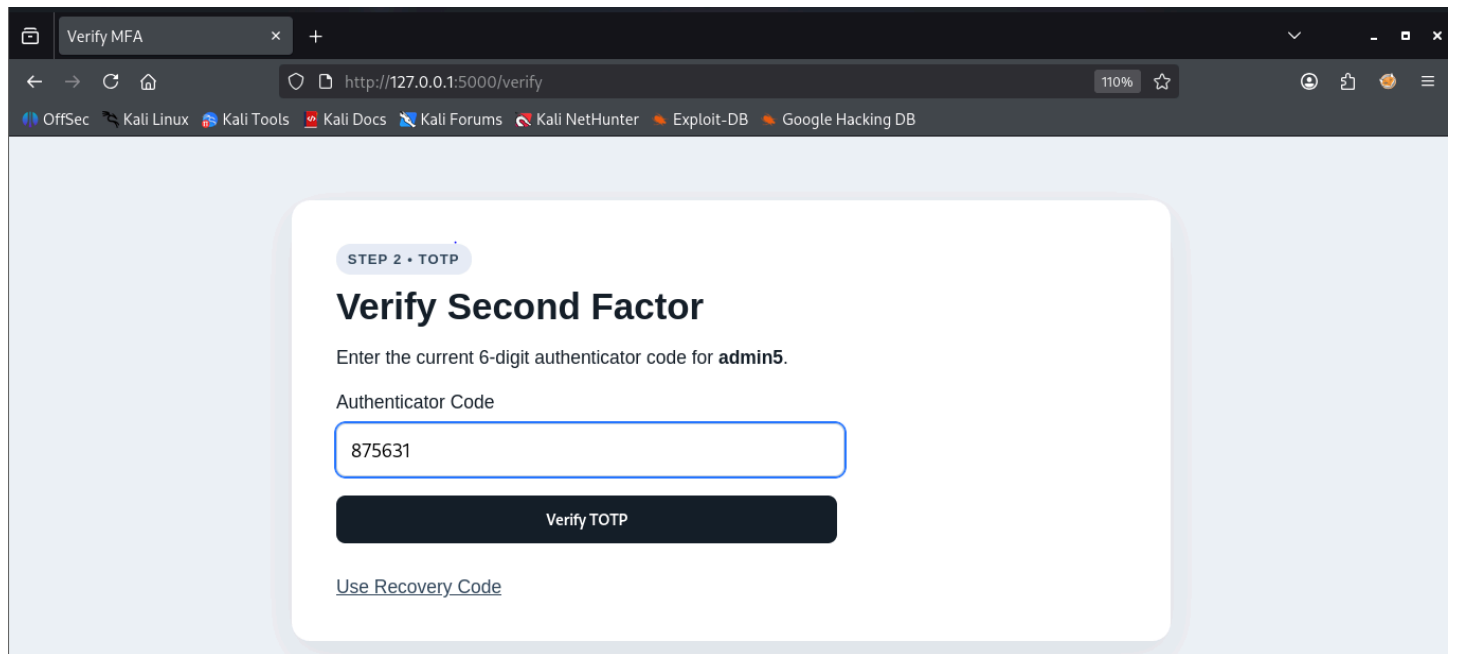


Valid TOTP

Expected Result: Code accepted

Status: PASS

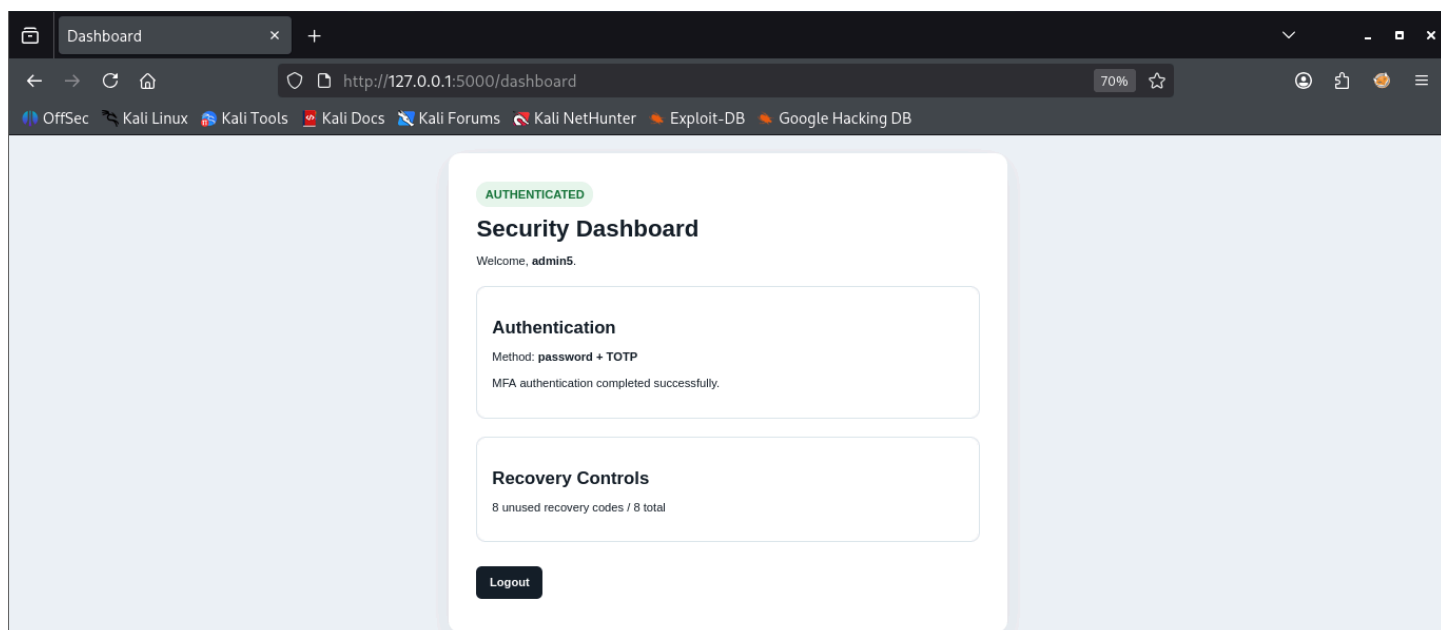
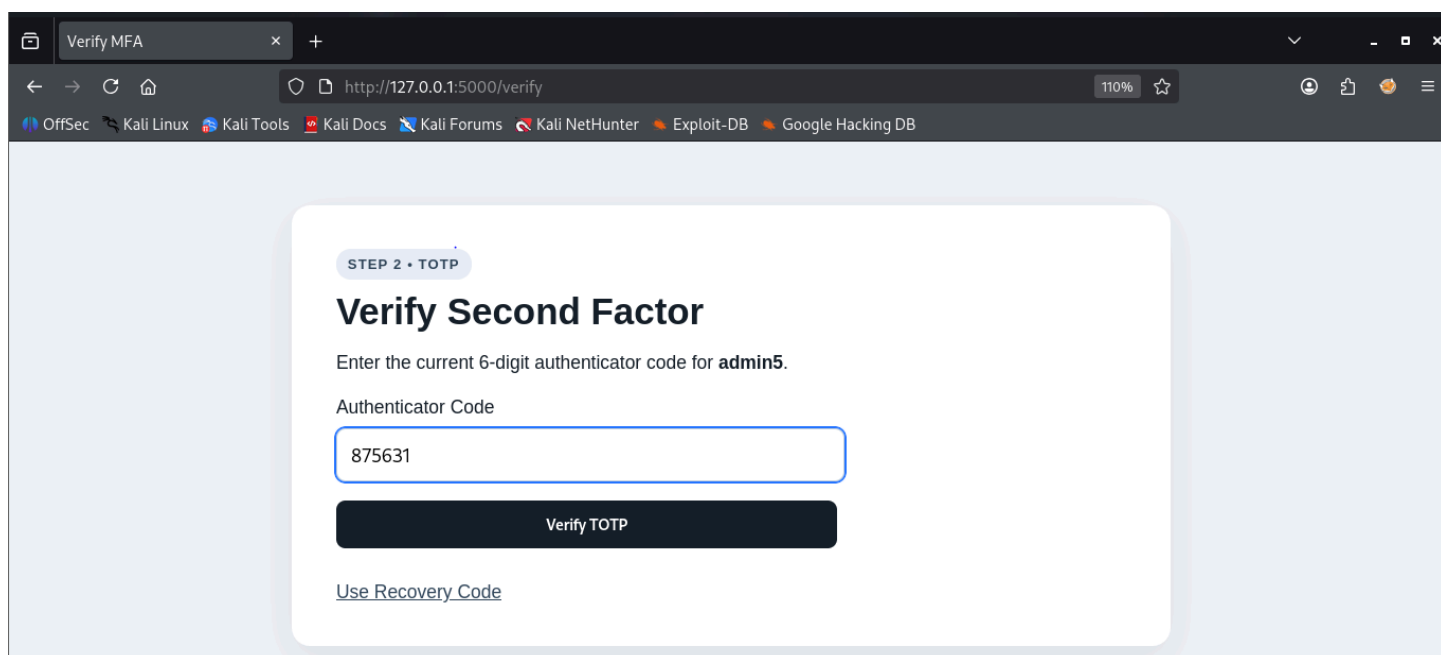
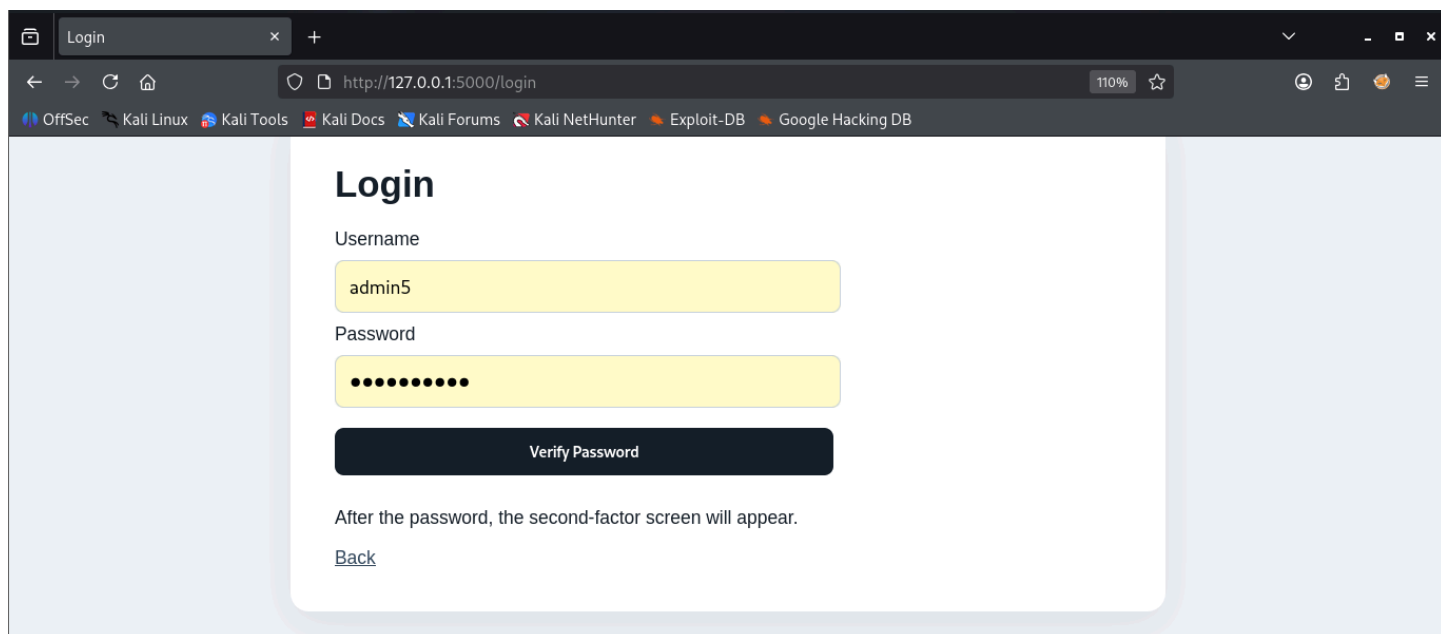




Password + TOTP

Expected Result: Authentication successful

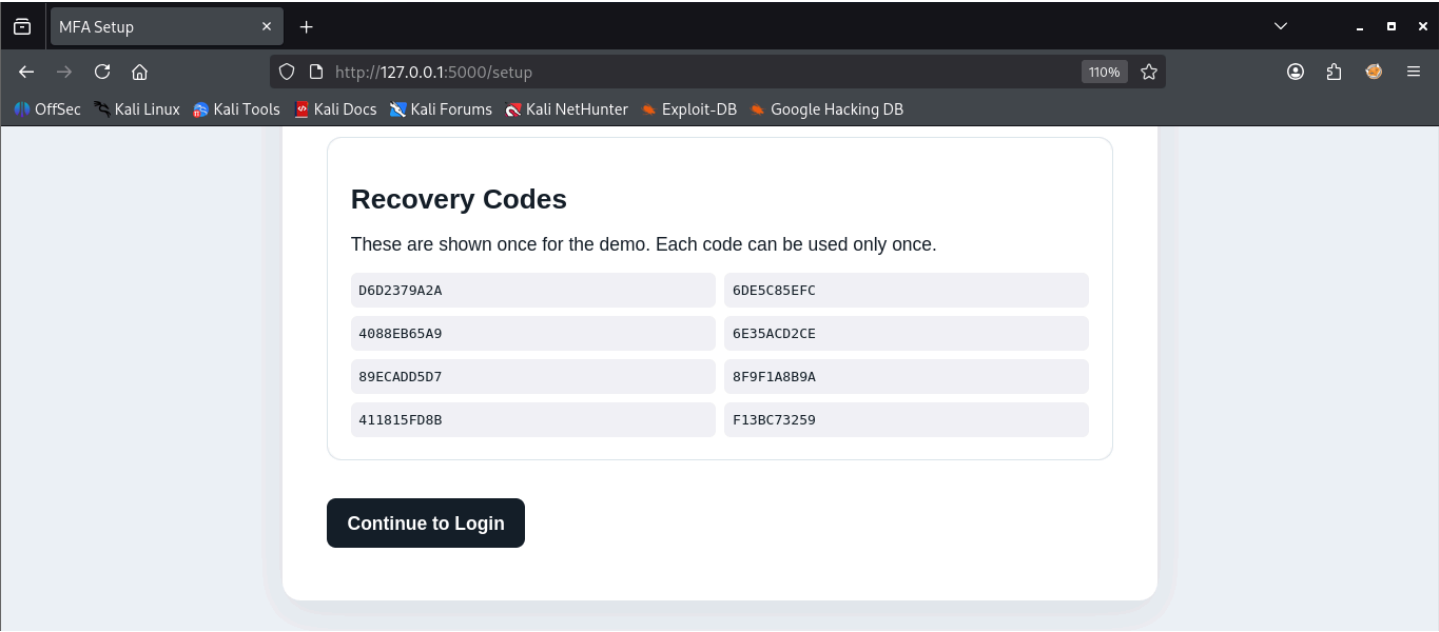
Status: PASS



Recovery Code Generation

Expected Result: Codes generated

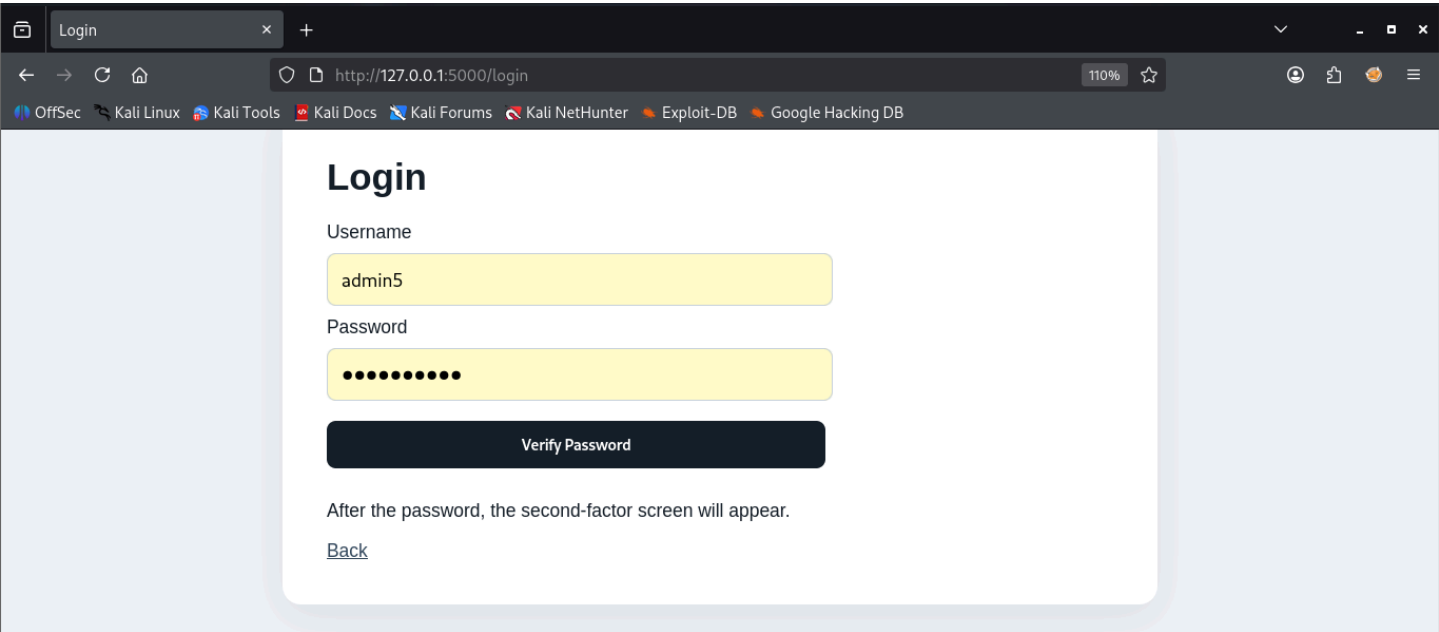
Status: PASS

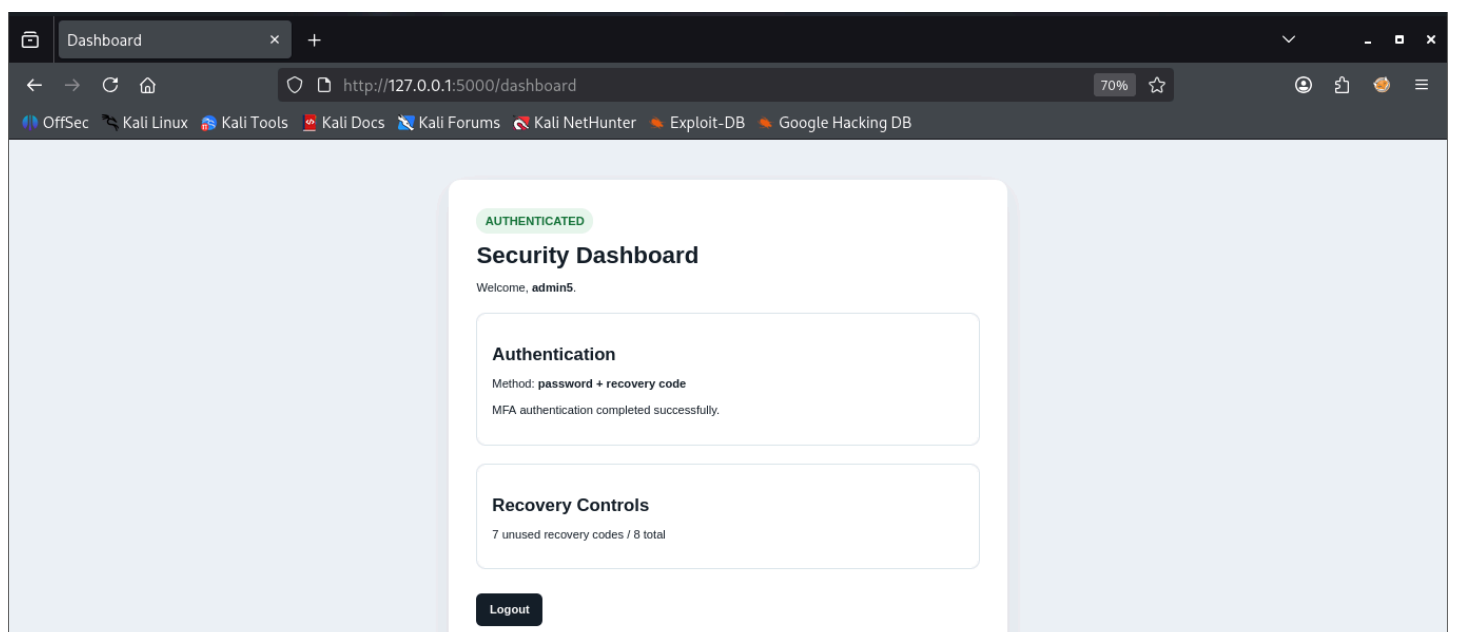
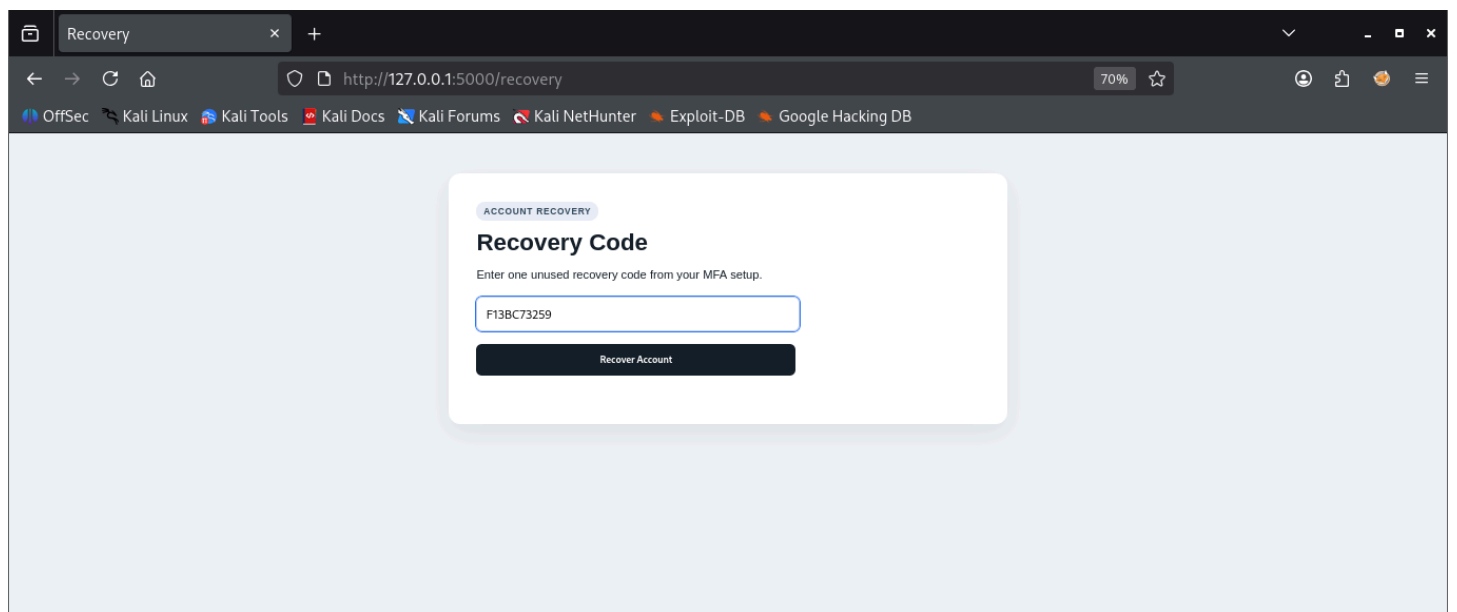
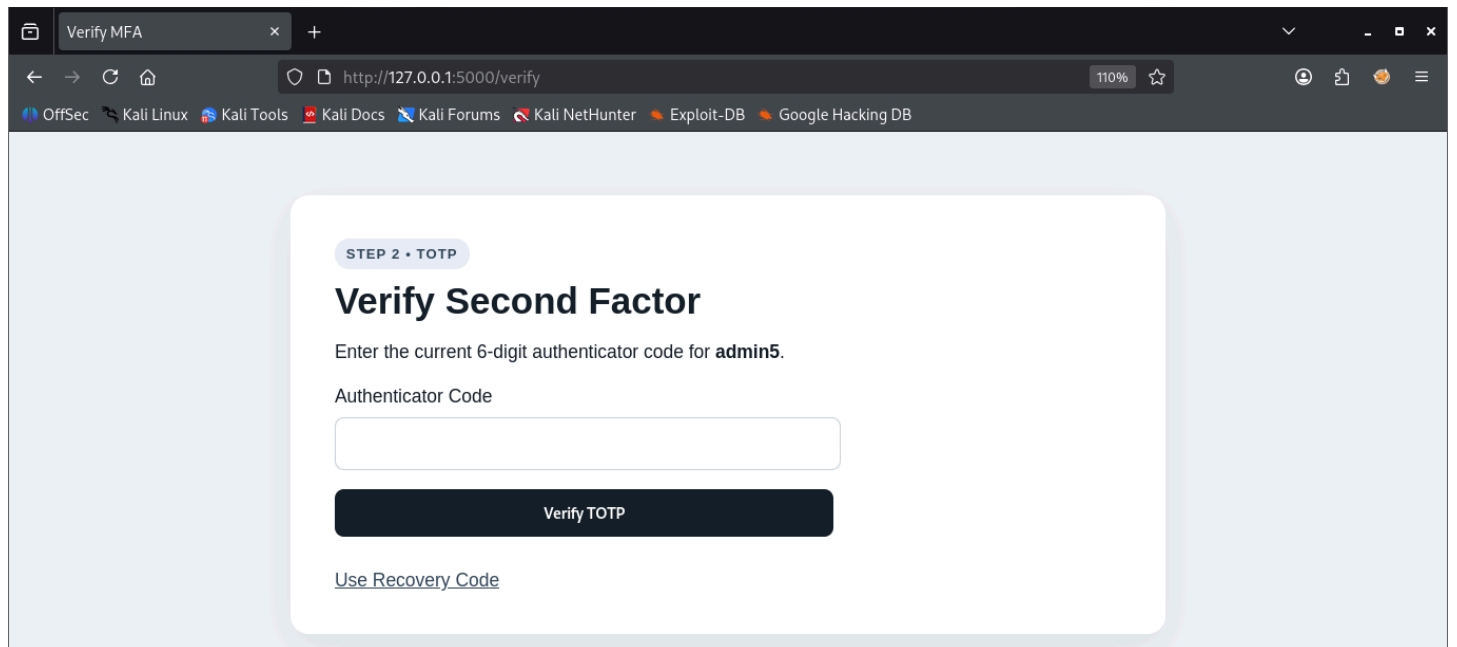


Valid Recovery Code

Expected Result: Recovery successful

Status: PASS

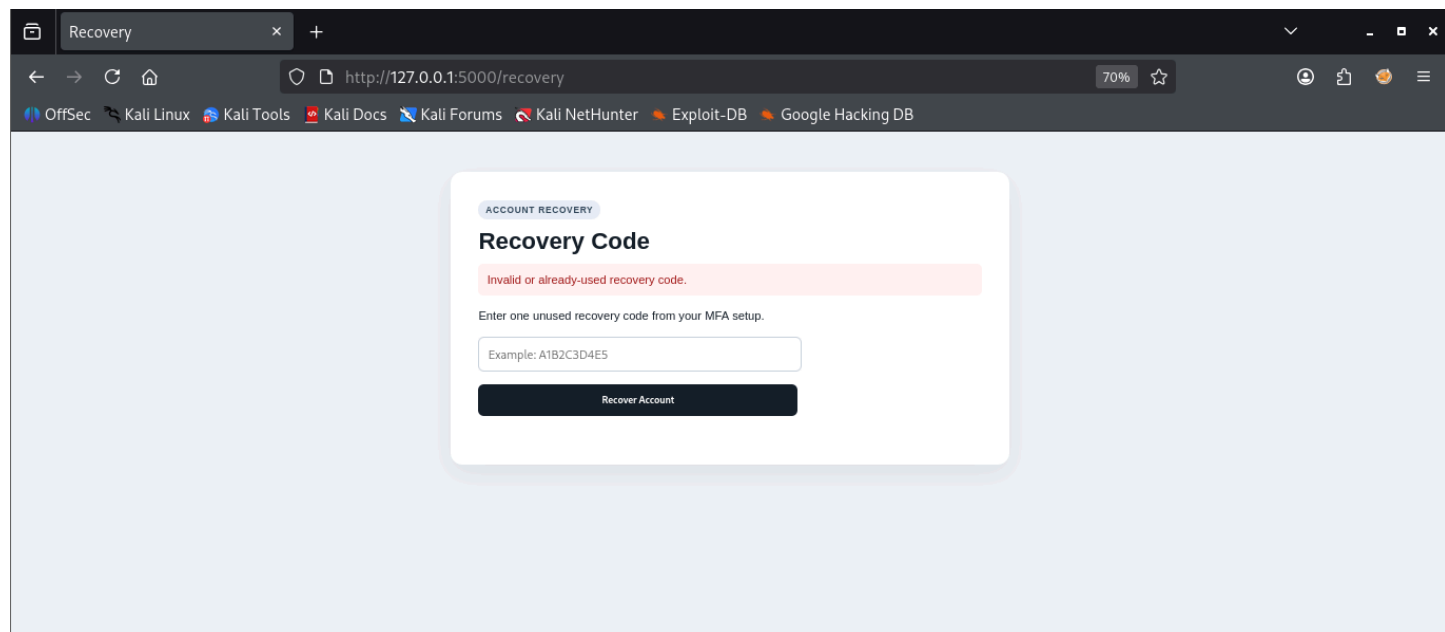
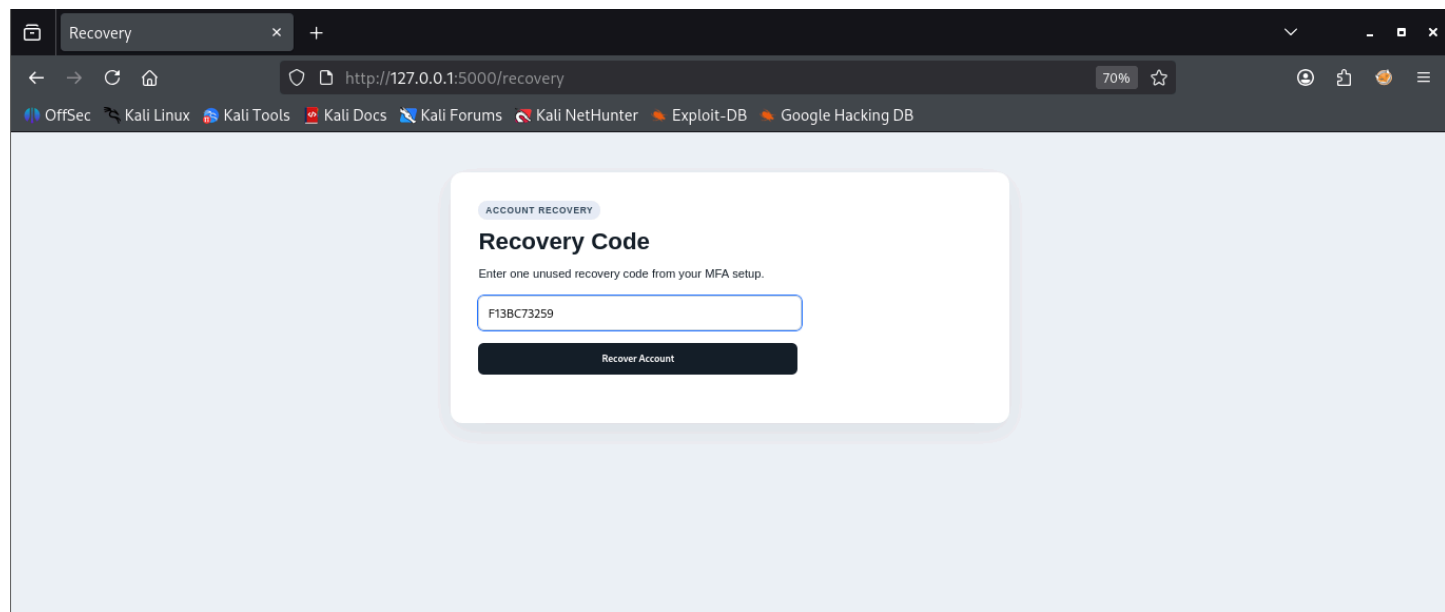




Reused Recovery Code

Expected Result: Code rejected

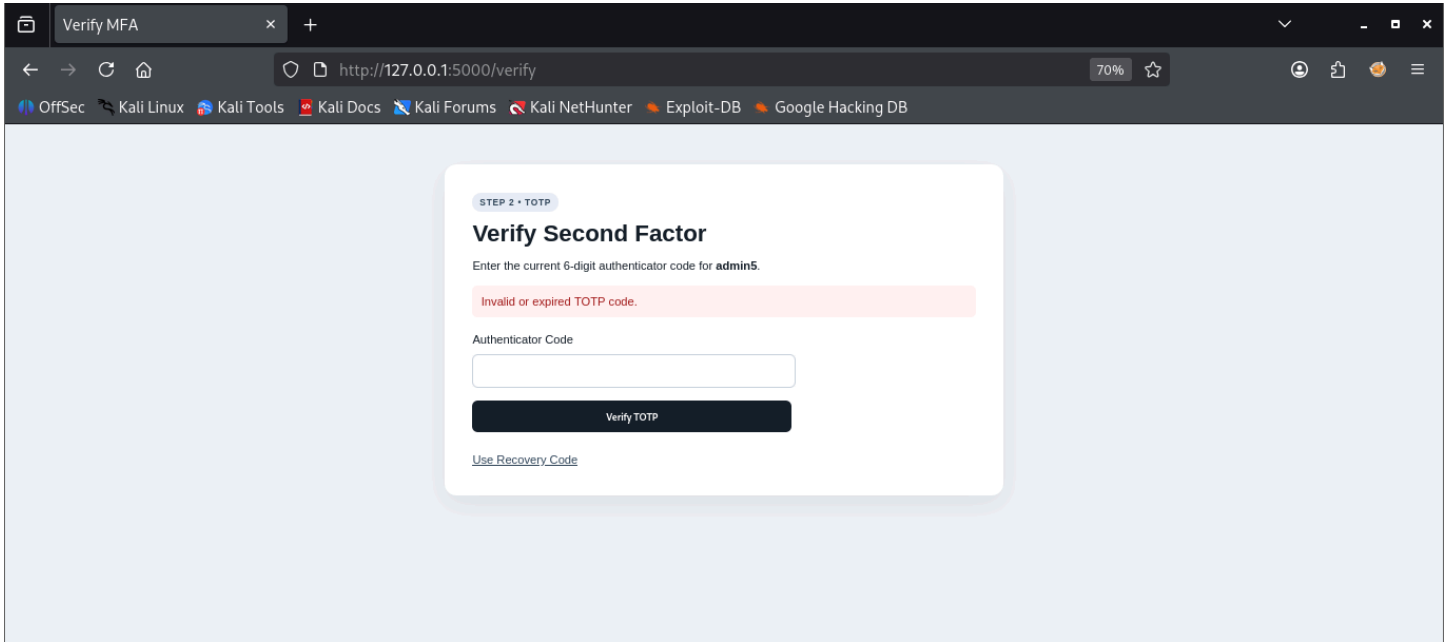
Status: PASS



Invalid TOTP

Expected Result: Authentication rejected

Status: PASS



Test Results

ID	Test Case	Expected Result	Status
01	User Registration	Account created	PASS
02	Correct Password	Password accepted	PASS
03	TOTP Setup	QR generated	PASS
04	Valid TOTP	Code accepted	PASS
05	Password + TOTP	Authentication successful	PASS
06	Recovery Code Generation	Codes generated	PASS
07	Valid Recovery Code	Recovery successful	PASS
08	Reused Recovery Code	Code rejected	PASS
09	Invalid TOTP	Authentication rejected	PASS